

Гайд по безопасному программированию

При построении современных веб-приложений разработчики уделяют наибольшее внимание самой начинке и стабильности работы. Оно и понятно, никому не понравится неопрятное окно, в котором не понятно, что и куда вводить, а после ввода выскакивают странные ошибки. Эти требования очевидны, не нужно описывать причины, почему каждый разработчик стремится их соблюдать.

Мы делаем приложения для нас и наших клиентов – людей и организаций, которые используют продукт для удовлетворения собственных нужд. Они используют функционал по назначению, в соответствии с определенными инструкциями и документацией. Клиенты тыкают кнопки в интерфейсе, создают документы и обмениваются ими. Многие даже примерно не представляют, как СБИС работает изнутри, они не знакомы с консолью, не знают, что такое JSON-RPC вызовы и чем отличается http от https.

Но среди таких пушистых одуванчиков встречаются и настоящие акулы – люди или группировки, целью которых является выполнение каких-то специфичных действий, непредвиденных разработчиком. Делается это, как правило, для извлечения финансовой выгоды, реже, для ухудшения репутации компании и переманивания клиентов к конкурентам. Таких людей/группировки называют блэкхэт хакерами, или просто блэчерами.

Блэчеры используют любые недостатки в системе (уязвимости) для получения содержимого базы данных, повышения привилегий в системе. Их атаки могут быть нацелены и на конкретных клиентов продукта – угон аккаунта, например, позволит узнать какую-то информацию по деятельности клиента. Наихудший случай – злоумышленник получает доступ к серверу внутри компании и продолжает развивать атаку изнутри. Каждый простой сервисов дорого обходится компании, слитая и выложенная на закрытом форуме база – еще дороже.

Причиной такого кошмара служит элементарное несоблюдение техник написания безопасного кода. С детства учат, переходя дорогу смотреть налево и направо, такой же простой анализ нужно выполнять каждый раз, когда разрабатывается новый функционал или изменяется старый.

Данный гайд содержит описание наиболее часто встречаемых уязвимостей в продуктах компании. Для каждого типа уязвимостей приводятся действия по их устранению.

Аббревиатуры, используемые в гайде:

БЛ - бизнес-логика

ГПСЧ - генератор псевдослучайных чисел

CSP - Content Security Policy, политика защиты контента

CVE - Common Vulnerabilities and Exposures, база данных общеизвестных уязвимостей информационной безопасности

CWE - Common Weakness Enumeration, список слабостей недостатков программного обеспечения

DoS - denial-of-service attack, отказ в обслуживании

DTD - Document Type Definition, стандарт описания фактической структуры XML-документа или его части

IDOR - insecure direct object reference, небезопасные прямые ссылки на объекты

LDAP - Lightweight Directory Access Protocol, облегченный протокол доступа к каталогам

MITM-атака - Man-In-The-Middle attack, атака «человек посередине»

NIST - The National Institute of Standards and Technology, Национальный институт стандартов и технологий США

OWASP - Open Web Application Security Project

SAST - Static Application Security Testing, статический анализ кода приложений

SSRF - Server-side request forgery, подделка запроса на стороне сервера

XSS - Cross Site Scripting, межсайтовое выполнение запросов

XXE - XML External Entity Attack, внедрение внешних сущностей XML